

PENJELASAN TERTULIS

Practical Assessment Cyber Range Engineering (Red vs. Blue Lab)

Skenario: "Cookie Reuse & MFA Bypass" SCENARIO75

Diajukan untuk: PT Nauli Mula Data

Oleh: Wakamiya

Posisi: Cybersecurity Engineer (Lab & Range Developer)

Deliverable teknis lengkap (source code, Docker Compose, script) tersedia pada Git Repository

1. Ringkasan Skenario

Skenario yang diminta adalah membangun sebuah "Admin Feedback System" yang sengaja dibuat rentan (vulnerable by design), untuk mensimulasikan kerentanan nyata: meskipun sistem sudah menerapkan Multi-Factor Authentication (MFA), logika penerbitan session token-nya cacat sehingga dapat dieksploitasi.

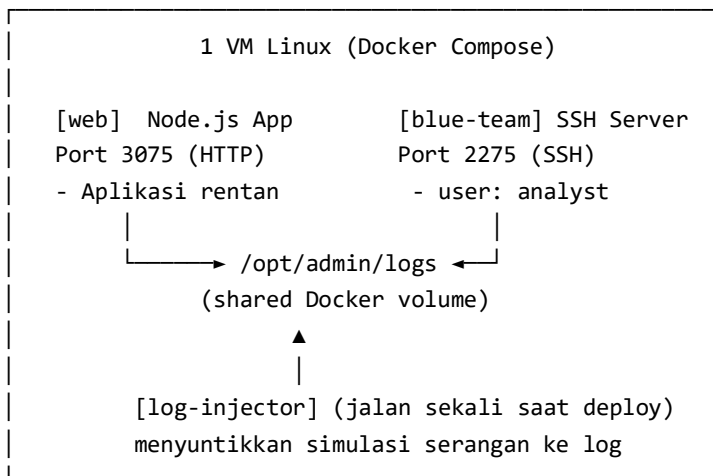
Alur serangan yang disimulasikan disebut Cookie Reuse & MFA Bypass, yaitu:

- Penyerang (Red Team) mencuri cookie sesi admin melalui celah Cross-Site Scripting (XSS).
- Cookie yang dicuri tersebut kemudian di-replay (digunakan ulang) langsung ke server.
- Karena bug pada backend, server tidak pernah memverifikasi ulang ke endpoint MFA sehingga penyerang berhasil masuk ke halaman admin tanpa perlu melalui proses MFA sama sekali.

Selain sisi serangan, environment ini juga menghasilkan log (telemetry) yang realistis, sehingga Blue Team dapat melakukan investigasi forensik dan menyusun kronologi insiden dari log tersebut.

2. Arsitektur Lab

Lab ini dibangun sebagai 3 container Docker yang saling terhubung dalam satu Docker Compose stack, dimaksudkan untuk berjalan di dalam 1 Virtual Machine Linux (baik di atas hypervisor Proxmox, VirtualBox, maupun VM lainnya arsitektur ini bersifat hypervisor-agnostic, karena yang dibutuhkan hanyalah Linux + Docker).



Ketiga container berbagi satu volume log yang sama (/opt/admin/logs), sehingga app menulis log, log-injector menambahkan bukti serangan simulasi, dan Blue Team membaca log tersebut lewat SSH meniru pola nyata di industri dimana log dikumpulkan terpusat untuk dianalisis.

Komponen	Fungsi	Port
web	Aplikasi Admin Feedback System yang rentan target serangan Red Team	3075 (HTTP)
blue-team	Server SSH untuk akses investigasi Blue Team	2275 (SSH)
log-injector	Job sekali jalan yang menyuntikkan log simulasi serangan saat deployment	

3. Alur Serangan Red Team (3 Fase)

Fase 1 Reconnaissance

Temuan	Detail
Header HTTP robots.txt	Response mengekspos teknologi backend via header X-Powered-By: Node.js
Petunjuk di source code	Secara tidak sengaja membocorkan endpoint tersembunyi /api/verify-mfa dan /dashboard
Cookie awal	Komentar ASCII art pada HTML mengarahkan penyerang untuk memeriksa robots.txt
	Cookie pre_mfa_session diterbitkan sebelum autentikasi, dengan flag HttpOnly bernilai False (rentan dibaca JavaScript)

Fase 2 Defense Evasion (WAF & XSS)

Temuan	Detail
WAF sederhana	Payload <script> standar berhasil diblokir dengan status 403
Celah bypass WAF	WAF tidak memeriksa elemen HTML5 seperti <svg onload=...>, sehingga payload XSS tetap bisa lolos
Obfuskasi	Karena akses langsung ke kata kunci 'document.cookie' diblokir, penyerang menggunakan notasi bracket JavaScript untuk menyamarkannya
Eksfiltrasi	Fungsi fetch() digunakan untuk mengirim cookie curian ke server milik penyerang secara real-time

Fase 3 Initial Access (MFA Bypass & Session Replay)

Temuan	Detail
Akar masalah	Backend hanya memeriksa apakah nama cookie diawali 'adm_sess' tidak pernah memverifikasi ulang ke /api/verify-mfa
Dampak	Cookie admin yang dicuri dapat langsung digunakan ulang (replay) oleh penyerang untuk masuk ke /dashboard tanpa melalui proses MFA
Bukti visual	Payload XSS yang tersimpan akan tampil di dalam elemen dengan class xss-payload pada halaman dashboard
Flag akhir	SCENARIO75{RED_C00k13_MFA_Byp4ss_0wn3d}

4. Alur Investigasi Blue Team

Blue Team mengakses server melalui SSH (port 2275, user analyst) untuk memeriksa dua file log yang tersimpan di /opt/admin/logs: access.log (aktivitas HTTP) dan error.log (peringatan aplikasi/WAF).

Langkah	Temuan di Log	Kesimpulan
1	Trafik dari 192.168.1.100 (internal) vs 10.10.14.50 (asing)	192.168.1.100 adalah baseline trafik admin yang sah; 10.10.14.50 (subnet 10.10.14.0/24) adalah IP penyerang
2	error.log mencatat blokir <script> pertama pada pukul 18:50:15	Percobaan payload XSS dasar berhasil dihentikan WAF
3	access.log: akses /dashboard status 200 pukul 18:51:55, disertai header mencurigakan berformat Base64	Penyerang berhasil masuk ke dashboard admin; ada indikasi eksfiltrasi data
4	String Base64 tersebut, setelah di-decode, menghasilkan flag rahasia	Decoding membuktikan cookie sesi admin telah dicuri dan digunakan ulang flag: SCENARIO75{BLUE_L0G_HUnt3r_M4st3r}

Langkah	Temuan di Log	Kesimpulan
5	error.log mencatat "Authentication bypass anomaly" pukul 18:53:10	Mengonfirmasi bahwa IP penyerang tidak pernah mengakses /api/verify-mfa MFA benar-benar dilewati

5. Cara Deploy & Reset Lab

Deployment (di dalam VM Linux, mis. Proxmox/VirtualBox)

- Install Docker & Docker Compose (dapat menggunakan script scripts/provision-vm.sh yang disediakan)
- Clone repository, lalu jalankan: `docker compose up -d --build`
- Aplikasi otomatis dapat diakses di port 3075, SSH di port 2275
- Container log-injector otomatis mengisi log simulasi serangan begitu stack pertama kali dijalankan

Reset ke Kondisi Awal

- `docker compose down -v / docker rm -f (container id)` → menghentikan semua container dan menghapus seluruh log/volume
- `docker compose up -d --build` → membangun ulang dari kondisi bersih, log simulasi otomatis terisi lagi

Catatan: data feedback yang disubmit (termasuk payload XSS) hanya tersimpan di memori container 'web', sehingga otomatis hilang setiap kali container tersebut direstart tidak memerlukan pembersihan manual.

6. Kesimpulan

Lab ini berhasil mensimulasikan satu skenario ancaman nyata secara end-to-end: dari reconnaissance, bypass proteksi WAF, pencurian sesi lewat XSS, hingga bypass MFA lewat session replay sekaligus menghasilkan telemetry yang cukup detail bagi Blue Team untuk merekonstruksi kronologi serangan tersebut murni dari analisis log. Seluruh environment bersifat portable (Docker-based) sehingga dapat digunakan berulang kali untuk sesi pelatihan Red vs Blue di lingkungan mana pun, termasuk Proxmox.

Source code lengkap, Docker Compose file, dan seluruh script pendukung tersedia pada Git Repository yang disertakan bersama dokumen ini.

Link Repo Github: <https://github.com/DarthWakamiya/Cyber-Range-Lab>